INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 3 Scenario-Based Assignment:

Risk Management Fundamentals

Student Name: Najma Abdi Omar

Reg. No: **2025/GRC/10331**

Date: 07/08/2025

Executive Summary:

TechStart solutions is a growing software development company with 150 employees across three locations, it develops custom solutions for clients and has cloud presence, recently the company has faced incidents involving cybersecurity and risk in general, involving a successful phishing attempt and also theft of a developer's laptop with sensitive information. A recent audit also revealed poor cyber safety hygiene, cases of back up failure and a client also reported an unauthorized access to their environment. This is not unique to TechStart, a lot of tech startups are facing growing cybersecurity challenges due to being solution oriented and the goal is speed over security and hence the need for frameworks to address the gap and ensure security as a design is established. In this section we explore the different aspects of Risk Management Framework, using industry best practice where we first Identified 15 key risks in TechStart using Vulnerability Scanning, Historical Data Analysis and Threat Modeling methods creating a risk register addressing potential impact and risk category. We also completed a comprehensive risk assessment using both Qualitative and Semi-Quantitative approaches and created a risk matrix diagram. The report also includes Risk mitigation strategies where we identified top 5 highest-priority risk and chose most appropriate treatment with justification and return on investment analysis. To formalize the risk management process, we recommended adopting the ISO 31000 framework incorporating the various process and plans that are provided as a guide, the framework was proposed due to its alignment with maturity level of TechStart, the requirement to comply with SOX and also the culture of the organization.

Section 1: TechStart Solutions Risk Identification

Section 1A: For Risk Identification we will use the methods:

1. **Vulnerability Scanning:** Based on the report, a routine audit identified outdated server, undertaking a vulnerability scan will assist us in identifying technical vulnerabilities and security weakness.

2. **Historical Data Analysis:** TechStart recently had several security-related incidents, reviewing this incident will assist in understanding existing gaps and risks associated with the gaps.

3. **Threat Modeling:** TechStart is a software development company with recent expansion into cloud services, which shows it is moving fast and with no mature risk framework, this model will assist in envisioning the unknown and help us capture potential risk.

Section 1.b: Risk Register:

Based on the methods above the below risk were identified and documented for TechStart.

Risk ID	Risk Name	Risk Description	Potential Impact	Risk Category	Method Used
1	Outdated Servers	Unpatched servers and legacy software use	Attackers could gain unauthorized access, system crash due to DOS attacks, and exploit of known vulnerabilities	Technical	Vulnerability Scanning
2	Default Credentials	Systems using default admin	Attackers could take advantage	Technical	Vulnerability Scanning

		credentials	of the known passwords for unauthorized access to the organization's network		
3	Weak Passwords	Identified multiple admins and normal users with weak passwords	Access to internal systems or applications through brute-force attacks to obtain sensitive information	Technical	Vulnerability Scanning
4	Exposed Sensitive Information	Identified sensitive data in web responses, this included user details and authentication data	Information Theft through the exposure in web response	Technical	Vulnerability Scanning
5	Network Vulnerability	Open Ports and weakness in firewall rules identified	Unauthorized users, malware installation, service disruption	Technical	Vulnerability Scanning
6	Unencrypted Source Codes	Recent theft of a developer laptop	Theft of sensitive information,	Technical	Historical Data Analysis

			reputational damage		
7	Successful Phishing Attempt	A phishing email successfully compromised an employee's credential which shows lack of user awareness training	Access to sensitive information, identity theft, data loss	Operational	Historical Data Analysis
8	Access Reviews	Unauthorized access of client development environment	Reputational damage, loss of data, damage to software	Operational	Historical Data Analysis
9	Inconsistent Back-up	Backup System failed during a recent power outage	Lack of Business continuity and Disaster Recovery	Technical	Historical Data Analysis
10	Credential stolen	The phishing success shows credential theft which can be used for internal system access	Insider Threat, data loss	Technical	Historical Data Analysis
11	Communication Gaps	Lack of coordinated and accurate	Reputational damage, lack of stakeholder	Operational(BAU)/ Strategic(long-term)	Threat Modeling

		information sharing between internal teams and lack of clear roles and responsibilities in BAU and IR	trust, Siloed work leading to double effort,		
12	Authorization issues	Lack of clear or poorly defined roles, users having more than one role(multiple hat scenario), non-existent maker-checker process	Data leaks, deletion of data, non-compliance fines(SOX)	Operational/Technical	Threat Modeling
13	Lack of Monitoring	There are no logs or monitoring of systems, admins visibility is minimal	Lack of compliance readiness, increased risk of breach, potential theft of credentials	Technical	Threat Modeling
14	Poor Cloud Configurations	Inadequate controls like lack of MFA, exposed DBs, lack of role based access,	Credential Theft, data loss, unauthorized access	Technical	Threat Modeling

		lack of encryption on stored data			
15	Lack of Data Recovery Process and Disaster Recovery(DR) policy	Lack of adequate Data recovery site, no policy on DR, lack of DR exercise for preparation	Loss of Data, successful Ransomwares, loss of customer and stakeholder trust	Strategic	Threat Modeling

Section 2: Risk Assessment

Section 2A: Qualitative Assessment:

Risk Name	Likelihood	Impact	Justification
Outdated Servers	Medium	High	A recent audit revealed outdated servers while the likelihood is low, the impact if vulnerabilities are exploited will cause a huge impact
Successful Phishing Attempt	High	Medium	Phishing is very common and lack of employee training or assessment will lead to more success as recently shown, impact is medium because full advantage is not a

			guarantee just from phishing there are other factors like privilege escalation etc.
Default Credentials	High	High	The likelihood of the default credentials stealing and exploited is high due to the nature of startups which are fast paced and security last mindset, impact is high if it happens due to the nature of data access.
Credential stolen	High	Medium	We have history of credential theft and the security set up is indicative of the likelihood, however we rate the impact as low because access alone will not guarantee success.
Lack of Data Recovery Process and Disaster Recovery(DR) policy	Low	High	We have cloud presence and this gives the low likelikhood rate, however the impact will be high
Poor Cloud Configurations	High	High	There are so many different clients and the

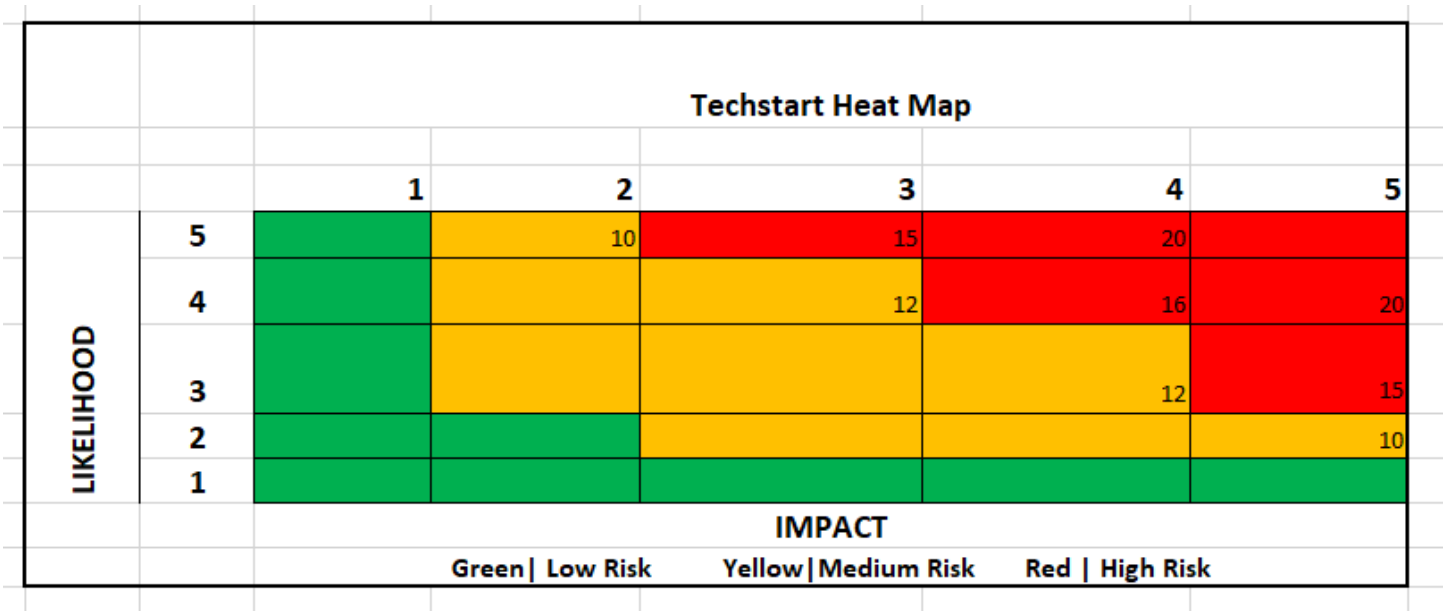
			report indicated an already existing issue of unauthorized access, hence the high likelihood the impact is also high due to the damage it may cause
Lack of Monitoring	Medium	High	The impact from exploiting lack of monitoring is high due to the nature of the actions that can be undertaken when exploited, like breach
Inconsistent Back-up	Medium	High	Recent Incident has shown failure in backup restoration which has high implication in data loss and Business continuity
Unencrypted Source Codes	High	High	Remote work means staff carrying work laptops and sensitive data outside office, recent loss of device adds to this, unencypted data has a big implication
Weak Passwords	High	Low	Likelihood of a successful

			brute force is high however impact is low because password alone cannot guarantee success in cyber breach.

Section 2B: Semi-Quantitative Assessment

Risk Name	Likelihood	Impact	Risk Score/Level	Risk Level
Outdated Servers	3	5	**15**	High
Successful Phishing Attempt	4	3	12	Medium
Default Credentials	4	4	**16**	High
Credential stolen	5	3	15	High
Lack of Data Recovery Process and Disaster Recovery(DR) policy	2	5	10	Medium
Poor Cloud Configurations	4	5	**20**	High
Lack of Monitoring	3	4	12	Medium
Inconsistent Back-up	3	5	**15**	High
Unencrypted Source Codes	5	4	**20**	High
Weak Passwords	5	2	10	Medium

Section 2C: Risk Matrix Diagram (Developed in Excel attached Screenshot Below):



Section 3: Risk Mitigation Strategy

Section 3A: Identified Risks and Strategy

1. Outdated Servers: Continued use of unpatched outdated and legacy systems expose the organization to potential huge impacts the likes of data breach, Denial of service, end of life support, loss of data if attacked, this will lead to loss of client data, source code and loss of stakeholder trust and brand or reputation damage and also compliance violation (SOX). This is why we choose to **Mitigate** the risk. The risk is severity is High and hence why we cannot avoid or accept it, it is not practical to transfer therefore we have to counter the risk with measures below.

Plan:

Controls: This will entail technical controls where we will patch the servers and upgrade the outdate or legacy systems. We will also train the internal IT team on continuous monitoring and updating or patching servers.

Timelines: Considering Patching of servers and upgrading legacy system, this will entail planning and procurement and also prioritizing while considering the impact on outages, we will plan for a phased approach which will be minimum 8 weeks and after that continuous monitoring.

Resource We will need financial resources for buying of the servers and the cost of upgrade and human resources for the implementation, upgrade and monitoring.

Success Matrix: reduced known vulnerabilities, compliance and full visibility of systems.

Responsible Parties: ICT Team for the implementation and assessment, Security Risk for the recommendation and best practices, Management Team for support of initiative and budget approvals, procurement team, for delivery of systems and software, vendor partner for implementation support and training of internal teams.

Cost Benefit Analysis: for the cost of the exercise estimated at $18,000 vs The potential loss estimated at $90,000 based on the nature of business, this is estimated as a net benefit of $72,000 which is almost a 4x.

2. Default Credentials: The use of default credentials in a tech start up is high due to the nature of the business speed first security later approach, however hackers take advantage of this default credentials since it is widely known and top brands carry similar passwords, the impact of a hacker penetration is high and damaging hence why we also choose to **mitigate** this.

Plan:

Change all default password and enforce a password policy including password age, history and complexity, also enforce MFA for the triple factor security such that we still have protection in the event of credential theft, train the employees especially ICT and Dev team on importance of changing default password and maintaining password hygiene. This will be scheduled for four days, 3 for password change and system hardening and 1 for training. We will need an ICT resource and Risk Resource, for the initial stage we will not invest in password manager and only advocate for password safety. Our success metrics will be fewer breaches, no default passwords identified when we redo Vulnerability scans and staff assessment on use of safe password. Our cost benefit will be a minimal implementation cost for the staff and investing in MFA which will be less than $1000 vs the potential benefit of reducing a breach which might cost upwards of $100,000.

3. Poor Cloud Configurations: Cloud security is of most importance since it entails client data and source codes, we will approach this risk with **Mitigation,** this by enforcing MFA, Implementing RBAC, encrypting data and segmentation. We will need a minimum of 8 weeks with support from Cloud Engineers and Risk team, and Identity Access Management specialist. Success matrix will be reduced unauthorized access, enforced MFA before access and high compliance rating. **The ROI is** high since we estimate the impact to be $300,000 and the mitigation to cost $15,000.

4. **Inconsistent Back-up:** Backup is a crucial in an organization and especially in TechStart considering its clientele and critical solution it is handling, lack of plan B in case plan A fails is critical and will lead to losses including financial and client trust not to mention brand reputation. We cannot transfer this risk, accept or avoid, the best approach will be to **mitigate.** This by a combination of Technical and Administrative approach, where we create back up policies and procedures, implement solutions that will automate back up and train the internal team on how to maintain continuous back-up so that when needed we do not encounter failures.

The plan will take a minimum of **6 weeks** where we will identify the critical systems and data that need back up, the resource handling it and procure the system that automate. **Estimated cost** of $8,000 and potential loss avoided in estimated $100,000 and reputational damage averted. We will also need an ICT, Risk, Admin and specialist to initiate and ensure continuous back up. Our success matrix will be logs to show back up and immediate failover plan.

5. **Unencrypted Source Codes:** we had a recent case of stolen developer laptop, a need for encrypting source code is high due to the nature of work of our employees which is remote and also the impact of leakage or theft. This risk should also follow the **Mitigate** method. This **will entail** enforcing encryption and investing in tools and training to allow that. We will need resource from ICT, vendor and Risk. With an implementation **timeline** of 4 weeks, and **estimated budget** $9,000 and potential loss averted $200,000. **ROI** is high. Our **success matrix** is all devices and source code encrypted and no loss of data in any state.

Section 4: Framework Application

Section 4A: Risk Framework Recommendation:

Based on the current maturity level, the nature of business and the SOX compliance requirement we have decided to implement the ISO 31000 due to below considerations

Consideration	Justification
Company Size and Maturity	The company size is small and with no visible risk maturity due to the nature of incident reported, starting with a complex framework like NIST RMF will strain the organization.
Industry Requirements	NIST is very formal with intertwined requirements previously made for federal government and although other industries have implement, it is not suitable in the tech industry where keeping up with ever changing requirements will be tough since it speed over security
Regulatory Obligation	TechStart is planning to comply with SOX which goes beyond cyber risk but takes an organization wide approach in risk assessment where ISO31000 is more suitable
Available Resources	NIST RMF is a resource intense framework due to complexities in documentation the steps and technical resource required, which can strain the small organization
Organizational Culture	The culture in a tech organization is fast paced and always beating deadlines, this requires a framework that will allow the freedom to choose best practice while not enforcing complexities and ever changing controls like NIST RMF. Therefore ISO 31000 is best used here.

Section 4B: A business Case of the Framework Implementation proposal

Plan	Details of Plan
Key Phases and Milestones	The key phases and milestones will be dictated by the ISO 31000 Process which are as below: Phase 1: Communication and Consultation: Ensure all stakeholders are always aware and are consulted on every step especially area of expertise. Milestone: Stakeholder communication achieved. Phase 2: Scope, Context and Criteria: set the scope and objective, identify the org's risk appetite, understand the environment and have an all-round idea on the approach to be taken Milestone: Understand environment you will be working with and the scope Phase 3: Risk Assessment: This is now where the actual work of risk begins once everything is established it involves three key steps: Identifying the risk, likelihood vs impact and deciding the risk treatment. Milestone: Risks are identified, prioritized and next plan established.

	Phase 4: Risk Treatment: This is where we implement the next action decided on phase 3, which entails either avoiding, accepting, mitigating or transferring the risk based on evaluation. Milestone: Risk have been Treated Phase 5: Monitoring and Review: This step is where we review what we Implement, monitor the effectiveness or the effect of the controls implemented. Milestone: Monitoring and Review established. Phase 6: Recording and Reporting: This phase is where we document and keep statements of what was done in all phases and updating stakeholders on the controls established and the updated risks emerging. Milestone: Documentation and Reporting established.
Timelines Estimates	We will propose a 12-week plan which will be sufficient and broken down as below: Phase 1: Communication and Consultation: Continuous throughout the 12-week key stakeholders updated at all times. Phase 2: Scoping: This is a rigorous exercise we give 2 weeks to sit with all departments and stakeholders maybe have workshops Phase 3: Risk Assessment: This is also another key step which involves three steps this will be 3 weeks Phase 5: Risk Treatment: this will be the bulk of the work where we implement what was discovered and agreed upon we give it 6 weeks. Phase 6: Monitoring and Review: This will be 2 weeks of post implementation health check Phase 7: Recording and Reporting: 12+ this will be continuous post implementation.
Resources Requirements	-Key Stakeholder Participation -ICT resource -Analyst -Risk Resource - Project Manager -Financial Support -Workshop
Success Factors	-Stakeholder Support -adopting risk based approach vs compliance based -Collaboration and elimination of Siloed approached. -Security inbuilt in process
Potential Challenges	-Lack of data or correct data -Lack of collaboration -Lack of support from management -lack of synergy and collaboration

Reference:

1. Week 3 Study Guide- Risk Management Fundamentals- ICDFA
2. Week 2 Study Guide – Regulatory Environment and Standards- ICDFA
3. Fundaments of Risk Management- Various YouTube educational Channels